

MetaMask Connect Audit Summary

Prepared by Cyfrin

Version 2.0

Lead Auditors

Raiders

Assisting Auditors

0xaudron

March 5, 2026

Contents

1 About Cyfrin 2

2 About This Document 2

3 Disclaimer 2

4 Copyright and License 2

5 Audit Overview 3

6 Audit Scope 4

7 Risk Classification 4

8 Protocol Summary 4

9 Attestation 4

1 About Cyfrin

Cyfrin is a Web3 security company dedicated to bringing industry-leading protection and education to our partners and their projects. Our goal is to create a safe, reliable, and transparent environment for everyone in Web3 and DeFi. Learn more about us at cyfrin.io.

2 About This Document

This document is a public summary of the security audit Cyfrin performed for MetaMask on Connect. It records the repositories and commits reviewed, the timeline, auditors, in-scope files, and the number and final status of findings by severity. It closes with Cyfrin's attestation of the review's scope and final remediation status.

It is deliberately abbreviated: the technical detail of individual findings is not reproduced here. The complete audit report, version 2.0 dated March 5, 2026, was delivered to MetaMask, who retain it as the full record of the engagement. This summary was issued on October 29, 2026.

3 Disclaimer

The Cyfrin team makes every effort to find as many vulnerabilities in the code as possible in the given time but holds no responsibility for the findings in this document. A security audit by the team does not endorse the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the in-scope code being audited. Unless the scope explicitly notes otherwise, the review is limited to the application layer and does not extend to the correctness of API/SDK/execution environment implementations, compilers, standard and third-party libraries, underlying operating systems and hardware.

4 Copyright and License

© 2026 Cyfrin Inc. All rights reserved. Material from MetaMask or third parties remains the property of its owners.

This summary may be shared only in complete and unmodified form, so that any copy can be checked against the hash in its attestation. Short quotations with attribution to Cyfrin are permitted, provided they do not misrepresent this summary's scope or results. Except as permitted by applicable law, no part of this summary may otherwise be copied, modified, adapted, sold or sublicensed, or used to create derivative works, without Cyfrin's prior written permission.

Cyfrin and the Cyfrin logo are trademarks of Cyfrin Inc. and may not be used to suggest that Cyfrin has reviewed or endorses anything outside this summary's scope, or to misrepresent its results.

5 Audit Overview

Over the course of 10 days, the Cyfrin team conducted an audit on the Connect code provided by MetaMask. The findings consist of 1 High, 5 Medium & 5 Low severity issues with the remainder being informational.

Summary

Project Name	Connect
Repository	mobile-wallet-protocol
Commit	565c8ef5b633...
Fix Commit	9a6ea640b448...
Repository 2	connect-monorepo
Commit	62d2948fe352...
Fix Commit	e9e2ade076ae...
Repository 3	metamask-mobile
Commit	c7685f0f170b...
Fix Commit	ca668952d2d8...
Repository 4	metamask-extension
Commit	bc6b0381b4ee...
Repository 5	va-mmcx-metamask-sdk-relay-server-workload
Commit	ef38a9e47ad9...
Audit Timeline	Feb 18th - Mar 3rd, 2026
Methods	Manual Review

Issues Found

Severity	Found	Resolved	Acknowledged
Critical Risk	0	0	0
High Risk	1	1	0
Medium Risk	5	4	1
Low Risk	5	4	1
Informational	3	3	0
Gas Optimizations	0	0	0
Total	14	12	2

6 Audit Scope

The audit scope covered the MetaMask Connect system across five repositories spanning the SDK layer, mobile wallet protocol, mobile and extension wallet integrations, and relay server infrastructure, at the commits listed in the Summary table.

The review was complemented by dynamic testing (E2E flows and fuzzing).

7 Risk Classification

	Impact: High	**Impact: Medium**	**Impact: Low**
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

8 Protocol Summary

MetaMask Connect enables dApps to communicate with MetaMask wallets across browser extension and mobile platforms through multiple transport layers, including a WebSocket-based Mobile Wallet Protocol (MWP) with end-to-end ECIES encryption and a browser-native extension path.

9 Attestation

Cyfrin attests that it performed a security review of the Connect code provided by MetaMask.

The repositories, commits, review period and findings with their final status are in the Summary and Issues Found tables in Section 5, and the in-scope files in Section 6. This attestation is limited to the documented scope, audited commits and mitigations specifically reviewed by Cyfrin.

Cyfrin publishes this document and its SHA-256 hash at https://github.com/Cyfrin/cyfrin-audit-reports. To check a copy on macOS or Linux, run the following in the folder that contains it; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name. Before running it, check that the URL is Cyfrin's repository.

```
U=https://github.com/Cyfrin/cyfrin-audit-reports/raw/main/reports/sha256
N=2026-03-05-cyfrin-metamask-connect-v2.0.pdf
F=$N
H=$(curl -fsSL $U/$N.sha256 | cut -d' ' -f1)
echo "$H *$F" | shasum -a 256 -c
```

Cyfrin's full audit report with all findings provided to MetaMask has the SHA-256 hash and file name below. To check a copy of it, first check this document as above, then run the following in the folder that contains the full report; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name.

```
H=5b40aa89283e7b4969ae82d3032e5439588a590ba011931deb7c0911bb3b44ed
F=2026-03-05-cyfrin-metamask-connect-v2.0-full.pdf
echo "$H *$F" | shasum -a 256 -c
```

On Linux, `sha256sum -c` can be used in place of `shasum -a 256 -c`. On Windows, run `Get-FileHash <file> -Algorithm SHA256` in PowerShell and compare the result with the hash.